

Information Security Management System Plan (ISO/IEC 27001:2022)

Langate Group

Table of Contents:

Purpose

Background and Objectives

ISMS Plan

- 4. Context of the organization
 - 4.1. Understanding the organizations and its context
 - 4.2. Understanding the needs and expectations of interested parties
 - 4.3. Determining the scope of the ISMS
- 5. Leadership
 - 5.1. Leadership and commitment
 - 5.2. Policies
 - 5.3. Organizational roles, responsibilities and authorities
- 6./8.1 Planning
 - 6.1. Actions to address risks and opportunities
 - 6.1.1. General; 6.1.2 / 8.2. Information security risk assessment
 - 6.1.3 / 8.3. Information security risk treatment
 - 6.2 Information security objectives and planning to achieve them
- 7. Support
 - 7.1. Resources and
 - 7.2 Competence
 - 7.3. Awareness
 - 7.4. Communication
 - 7.5. Documented Information
 - 7.5.1. General
 - 7.5.2. Creating and updating
 - 7.5.3. Control of documented information
- 9. Performance Evaluation
 - 9.1. Monitoring, measurement, analysis and evaluation
 - 9.2. Internal audit
 - 9.3. Management review / 10.1. Continual improvement / 10.2. Nonconformity and corrective action

APPENDIX A

- Internal Audit Plan and Procedure
 - Purpose
 - Scope
 - Roles and responsibilities
 - Plan
 - Procedure

Purpose

This Information Security Management System (ISMS) Plan aims to define the principles, requirements, and basic rules for establishing, implementing, and operating the Information Security Management System.

Background and Objectives

The ISMS Plan lays the foundation of the company's Information Security Management System and identifies the roadmap for the establishment, implementation, and operation of the ISMS and its continued efficacy. This document is supplemented by security policies and procedures that enable the treatment of risks to the organization.

Key objectives of the ISMS Plan are to:

- Define the context of the organization
- Define the scope of the ISMS
- Provide guidance for the implementation of risk assessment findings into a Statement of Applicability
- Provide proper steps and timelines for the implementation and maintenance of the ISMS
- Outline the internal audit process, audit reviews, and remedial actions
- Identify all necessary documents and records
- Continual improvement of the ISMS

ISMS Plan

4. Context of the organization

4.1. Understanding the organizations and its context

To establish an effective ISMS, have a better understanding of relevant information security issues, develop successful strategies, and allocate appropriate resources to garner optimal results, Langate Group will define its internal and external context as they pertain to information security.

Internal and external issues are factors relevant to Langate Group's purpose that affect Langate Group's ability to achieve the intended outcomes of its ISMS.

Internal issues include, but are not limited to:

- Governance, organizational structure (see Organization Chart), and roles and responsibilities for the ISMS (see Skills Matrix)
- Policies, objectives, and the strategies in place to achieve them
- Company culture, values, mission, and vision (see Information Security Policy)
- The flow of information and the decision-making process (see Information Security Policy)
- Capabilities (e.g., capital, time, people, processes, systems, and technology)
- Form and extent of contractual relationships (see Vendor Management Policy)

External issues include, but are not limited to:

- Information Security laws and regulations that are applicable to the company (see below)
- Social and cultural
- Interested parties (see below) and their cultures
- Market trends and customer preferences
- Political, public policy, and economic changes
- Technological trends that could impact implemented security controls

4.2. Understanding the needs and expectations of interested parties

APPLICABLE LAWS AND REGULATIONS (EXTERNAL)		<i>Requirements / Notes</i>	<i>Responsible Party</i>
International	GDPR	Consider global data protection and cybersecurity standards like GDPR (if dealing with EU data).	Lawyer
Federal	HIPAA, NIST	Adherence to laws like HIPAA (for health information), Sarbanes-Oxley Act (for financial data), and the Cybersecurity Framework by NIST.	Lawyer
State	CCPA	Security provisions of CCPA are met by ISO 27001.	Lawyer
Local (USA)	Local laws	Local laws and regulations as applicable in Fort Lee, NJ for data protection and cybersecurity.	Lawyer
Local (Ukraine)	Local laws	Local laws and regulations applicable to Ukrainian entities. List: https://langate.atlassian.net/wiki/x/BACqeQ	Lawyer

CONTRACTUAL REQUIREMENTS (EXTERNAL)		<i>Requirements / Notes</i>	<i>Responsible Party</i>
Customers	Langate Group provides a provision in all contracts between Langate Group and customers that an ISO 27001 will be provided for their review.	ISO 27001 Certification	ISMS Manager

INTERESTED PARTIES (INTERNAL/ EXTERNAL)		<i>Requirements / Notes</i>	<i>Responsible Party</i>
Customers	Customers are interested in gaining assurance that Langate Group protects the data provided to them.	Evidence that customer data is protected. ISO 27001 certification demonstrates this.	ISMS Manager
Suppliers	Suppliers need to ensure that the security of their data is maintained when in partnership with Langate Group	Suppliers accessing Langate Group's IT infrastructure, services and products are required to undergo a review of their ability to ensure data security throughout the supply chain.	ISMS Manager
Regulators	Compliance with applicable legal and regulatory requirements regarding data protection and	Adherence to regulations should be documented and ISO 27001 certification can be used to demonstrate compliance in audits.	ISMS Manager, Lawyer

	cybersecurity.		
Contractors	Contractors must ensure that they comply with the organization's security policies when handling its data.	Security clauses should be included in contracts, requiring contractors to be ISO 27001 compliant.	ISMS Manager
Management (C-level)	Management is responsible for overseeing the establishment, implementation, maintenance, and continual improvement of the ISMS.	C-level managers must lead the security culture and ensure the ISMS is properly resourced and implemented.	CEO, CTO, COO, ISMS Manager

DEPARTMENTS & BUSINESS UNITS (INTERNAL)		<i>Requirements / Notes</i>	<i>Responsible Party</i>
Delivery	Management of Langate Group has determined that a structured approach to implementing security control is needed for the delivery process at Langate Group. Management of Langate Group agrees that Annex A 5.8 of ISO 27001 meets the business requirements to fulfill this.	A more structured approach to implementing security controls.	Head of Delivery, Project Manager, CTO
HR	Management of Langate Group has determined that additional controls related to onboarding and terminations are required at Langate Group within the Human Resources department. Management of Langate Group has determined that Annex A 6.0 of ISO 27001 will fulfill the need for these controls.	More formalized onboarding/offboarding process.	Human Resources Manager, Director of Human Resources
Security	Management of Langate Group has determined, with input from the Security team, that an organized approach is needed to reduce the time that the Security team spends selecting security controls to implement. Management and Security have determined that ISO 27001 provides an organized framework for the management of Information Security within an organization which meets the needs of Langate Group.	Reduced time spent selecting security controls for implementation.	ISMS Manager, IT Manager/ Security Officer

4.3. Determining the scope of the ISMS

This document defines the boundaries of the Information Security Management System (ISMS) for entities united by the common name Langate Group and applies to all matters related to the ISMS, including documentation and activities.

This document will be used by:

- Langate Group Management
- Members responsible for the implementation of the ISMS

Through this document, Langate Group will define the boundaries of its ISMS by outlining information that needs to be protected. This information is under the direct responsibility of Langate Group and will be safeguarded regardless of whether it is being additionally stored, processed, or transferred in or out of the ISMS scope. In the event of the transfer of information out of the ISMS, the responsibility of applying security measures will be transferred to the external party responsible for its management.

The following items will establish the ISMS boundaries of Langate Group within the context of legal, regulatory, contractual, interested parties, and other stated requirements:

- Entities
 - Langate Corp.
 - LLC "JUST UA"
 - LLC "MEDBILLING"
 - LLC "WORKBASE"
- Organizational Units
 - Top Management
 - Delivery
 - PMO
 - HR
 - Recruitment
 - Marketing
 - Sales
 - IT
 - Finance
 - Legal
- Networks and IT Infrastructure
 - The ISO/IEC 27001:2022 certification scope includes Microsoft IT infrastructure components. This includes all hardware, software, networks, and facilities that store, process, or transmit organizational data.
- Processes and Services
 - Software Development Services
 - IT Outsourcing
 - Staff Augmentation
 - Medical Billing Services Through Outstaffing
- Locations
 - USA, Headquarters: 1150 Harvard PI, Fort Lee, NJ 07024;
 - USA, NYC office: 1460 Broadway, NYC, NY 10036;
 - USA, Colocation: Rackspace, 125 Belmont Ave, Somerset, NJ;
 - Ukraine, Partner office: Serpova Street 4B, Kharkiv, 61000;
 - Ukraine, Partner office: Naukova Street 7D, Lviv, 79060

EXCLUSIONS. The following items are explicitly excluded from the ISMS scope of Langate Group:

- None

5. Leadership

5.1. Leadership and commitment

To ensure the success of the Information Security Management System (ISMS), the management team of Langate Group must be fully aware and appropriately engaged in matters involving the ISMS. Management must provide proper resources (e.g., personnel, funding, etc.) for establishing, implementing, and maintaining the ISMS.

Top Management shall demonstrate its leadership and commitment through:

- Establishing an information security policy
- Ensuring ISMS, roles, responsibilities, and authorities are assigned
- Communicating the importance of effective information security management

Management commitment can be demonstrated, for example, by:

- Motivating & empowering persons to contribute to the effectiveness of the ISMS
- Reinforcing organizational accountability for information security management results
- Creating and maintaining an internal environment in which persons can become fully involved in achieving the organization's information security objectives

5.2. Policies

In addition to this plan, the information security plans, processes, and procedures of Langate Group will be outlined in a series of policies that define the vision and mission of Langate Group's management as to what needs to be achieved to ensure the protection of information and how that will be accomplished. These policies will include:

- Information Security Policy
- Acceptable Use Policy
- Asset Management Policy
- Backup Policy
- Business Continuity/Disaster Recovery Plans
- Code of Conduct
- Change Management Policy
- Data Classification, Retention, and Protection Policies
- Encryption and Password Policies
- Incident Response Plan
- Physical Security Policy
- Personal Data Processing Policy
- Responsible Disclosure Policy
- Risk Assessment Policy
- Software Development Life Cycle Policy
- System Access Management Policy
- Vendor Management Policy
- Vulnerability Management Policy

5.3. Organizational roles, responsibilities, and authorities

The objectives and measures outlined by this plan and associated policies shall be maintained and enforced by the roles and responsibilities specified in each policy and the company *Skills Matrix* (see below).

SKILLS MATRIX

Role Title	Job Description	ISMS Responsibilities
ISMS Manager	Responsible for the strategic leadership of the organization's information security program. Oversees the development and implementation of information security policies and procedures.	a) The design, development, maintenance, dissemination, and enforcement of the items contained in this policy and other ISP policies. b) Ensuring that the information security management system conforms to the requirements of ISO/IEC 27001:2022. c) Reporting on the performance of the information security program to top management to identify areas for continuous improvement (5.2d, 5.3b).
IT Manager/ Security Officer	The IT manager or security officer focuses on the technical aspects of information security when implementing ISO 27001. He or she is responsible for implementing and maintaining technical security measures, conducting vulnerability assessments and penetration tests to identify vulnerabilities, managing security incidents and breaches, and monitoring security-related technical infrastructure and tools.	a) Implementing technical measures b) Contacting assessments and managing incidents c) Maintaining security awareness and training programs
Compliance Manager	Oversees the organization's compliance with legal, regulatory, and contractual obligations. Develops and implements compliance programs and ensures that operations and business practices are aligned with applicable laws and regulations.	a) The design, development, maintenance, dissemination, and enforcement of the items contained in this policy and other ISP policies. b) Ensuring that the

		information security management system conforms to the requirements of ISO/IEC 27001:2022. c) Reporting on the performance of the information security program to top management to identify areas for continuous improvement (5.2d, 5.3b).
Internal Auditor	Conducts objective reviews of internal controls, processes, and procedures to ensure compliance and risk management standards are met. Evaluates the effectiveness of risk management, control, and governance processes.	a) Conduct annual Internal Audits to drive Continuous Improvement across the Drata ISMS.

6./8.1 Planning

6.1. Actions to address risks and opportunities

6.1.1. General; 6.1.2 / 8.2. Information security risk assessment

Methodology. Langate Group will establish a well-defined methodology for risk assessment tailored to the company's circumstances and needs, which will include the method of defining the following (see Risk Assessment Policy):

- Risks that could cause the loss of confidentiality, integrity, and/or availability of information
- Identity of risk owners
- Assessment consequences and the likelihood of the risk
- Risk calculation
- Risk acceptance

The risk methodology will ensure that the risk assessment results are consistent across all relevant company sectors with comparable results.

Performance. Langate Group will conduct a risk assessment as outlined in its Risk Assessment Policy and will produce a Risk Assessment Report.

6.1.3 / 8.3. Information security risk treatment

- **Risk Treatment Plan.** The Risk Treatment Plan is a crucial part of the ISMS implementation. Langate Group will have a well-defined Risk Treatment Plan outlining how the Statement of Applicability controls will be implemented, including responsible parties, timing and intervals, and allocated resources/budgets.
- **Evaluation of Effectiveness.** Langate Group will measure and evaluate the fulfillment and effectiveness of the controls in place and other ISMS objectives in place, as outlined in the Risk Treatment Plan.
- **Statement of Applicability.** The Statement of Applicability (SOA) links Langate Group's risk assessment

and treatment with the implementation of the ISMS. It gives the company an overview of what needs to be done in information security, why, and how.

6.2 Information security objectives and planning to achieve them

Information security objectives will be established in accordance with Langate Group's *Information Security Policy* and will consider any applicable information security requirements, as well as risk assessment and treatment results. The information security objectives will be measurable, if and when practical, and will reflect:

- What will be done
- Resources Required
- Responsible Parties/Personnel
- Completion Timeline
- Metrics for Evaluation and Acceptance Criteria

Langate Group's information security objectives will reflect 5-7 objectives that will cover Confidentiality, Integrity, and Availability as it relates to Langate Group's ISMS. The objectives will be tracked and updated when needed (*see table below*).

INFORMATION SECURITY OBJECTIVES

OBJECTIVES (Year 1 Post-Certification)	DEADLINE	RESPONSIBLE	Result
Conduct and document Business Continuity Plan testing (2025)	October 31, 2025	ISMS Manager, ISMS Committee	Done
Implement YouTrack tool to Standardize handling and tracking of requests and incidents	October 31, 2025	ISMS Manager, IT Manager	Done
Remediate identified certification audit non-conformities	December 31, 2025	ISMS Manager, ISMS Committee	Done
Implement Microsoft 365 Data Classification	December 31, 2025	ISMS Manager, IT Manager	Done
Information security training for all key resources	March 31, 2026	ISMS Manager, HR	Done
Organize an Internal Audit	April 30, 2026	ISMS Manager, Internal auditor	Done
Successfully pass the ISO/IEC 27001 Year 1 Surveillance Audit	May 31, 2026	ISMS Manager, Auditor	In progress
Define and integrate automated technical controls for the	June 30, 2026	ISMS Manager	In

Personal Data Processing Policy			progress
Increase Microsoft security score from 62% to 75%	August 31, 2026	ISMS Manager, IT Manager	Done
Conduct and document Business Continuity Plan testing (2026)	October 31, 2026	ISMS Manager, ISMS Committee	Planned

6.3 Planning of changes

All changes to the ISMS will be made in accordance with Langate Group's *Change Management Policy*. This will include planned and unplanned changes impacting the organization, software development, supplier services, and configuration management.

7. Support

7.1. Resources and 7.2 Competence

The proper operations and maintenance of the ISMS require proper personnel planning and resources. Langate Group management is devoted to ensuring that the ISMS roles and responsibilities, as well as the skills necessary to perform them, are well-defined and that those roles are properly manned by people with the requisite skills (see Skills Matrix above). Records of competence will be maintained. Management will also ensure that the ISMS is prioritized in the budgeting process and properly resourced to guarantee optimal performance.

7.3. Awareness

To ensure the proper implementation of the controls, policies, and procedures, Langate Group will promote awareness and provide training as to the necessity of such provisions and how to perform their roles and responsibilities in accordance with these provisions.

7.4. Communication

Langate Group's communication plan outlines the lines of communication within the organization and with outside entities to include appropriate government agencies (e.g., law enforcement) and non-governmental organizations. It also defines events and situations, and personnel responsible for the communication (see below).

COMMUNICATION PLAN

Document/ Deliverable	Frequency of Communication	Sender (Delivery from)	Audience (Delivery to)	Delivery Type	Delivery Evidence
Internal Audit Report	Annually	Internal Auditor	ISMS Manager	Email Documents	Email Committee

			ISMS Committee	(OneDrive) Confluence Page	Meeting Minutes
External Audit Report	Annually	External Auditor	ISMS Manager Board of Directors	Email Documents (OneDrive) Confluence Page	ISMS Committee and/or Board of Directors Closing Meeting Minutes
ISO 27001 Certificate	As New Certificates are Issued	External Auditor	Posted on company website Marketing Sales	Email Web Posting	Email Website
Corrective Action Report	After Internal/ External Audits	ISMS Manager	CEO	Microsoft Teams Meetings Documents (OneDrive) Confluence Page	Microsoft Teams Meeting Minutes
ISMS Security Objectives	Quarterly	ISMS Manager	CEO	Microsoft Teams Meetings Drata Policy Center	Microsoft Teams Meeting Minutes
Risk Treatment Plans	Quarterly	ISMS Manager	CEO	Microsoft Teams	Microsoft Teams

				Meetings Documents (OneDrive) Confluence Page	Meeting Minutes
Management Review Report	Annually or as necessary	ISMS Manager	CEO	Microsoft Teams Meetings Documents (OneDrive) Confluence Page	Microsoft Teams Meeting Minutes
External Incident Response Report	As necessary	Designated member to communicate with external parties (e.g., government agency, NGOs, etc.)	External Parties (e.g., government agencies, NGOs, etc.)	Microsoft Teams Phone As required by local regulations or standards	Appropriate Records

7.5. Documented Information

7.5.1. General

The following table includes the documents determined by Langate Group as necessary for the ISMS's effectiveness.

MANDATORY RECORDS & DOCUMENTS

Document	Reference	Location
----------	-----------	----------

ISO 27001:2022 TIER 1 DOCUMENTATION		
Scope of The Information Security Management System (ISMS)	Clause 4.3	<i>Section 4.3 of the ISMS Plan</i>
Information Security Policy	Clause 5.2	<i>Drata Policy Center</i>
Definition of Security Roles & Responsibilities	Clause 5.2, Annex A.6.2	<i>Skills Matrix section of the ISMS Plan</i>
Information Security Objectives	Clause 6.2	<i>Information Security Objectives section of the ISMS Plan</i>
Risk Assessment Process	Clause 6.1.2	<i>Drata Policy Center</i>
Risk Assessment Report	Clause 8.2	<i>Confluence Page</i>
Risk Treatment Process	Clause 6.1.3	<i>Drata Policy Center</i>
Risk Treatment Plan	Clause 6.1.3e	<i>Drata Risk Assessment module and Confluence Page</i>
Statement of Applicability	Clause 6.1.3d	<i>Drata Policy Center</i>
List of Interested Parties, Legal & Other Requirements	Clauses 4.2 & 6.1	<i>Section 4.2 of the ISMS Plan</i>
Internal Audit Plan & Reports	Clause 9.2	<i>Documents (OneDrive)</i>
Results of Management Reviews of ISMS	Clause 9.3	<i>Documents (OneDrive)</i>
Nonconformities, Corrective Actions & Improvement Suggestions	Clause 10.1; 10.2	<i>Documents (OneDrive)</i>
ISO 27001:2022 TIER 2 DOCUMENTATION		
Inventory of Assets	Annex A.5.9	<i>ItFin/OneDrive/Drata</i>
Acceptable Use of Assets	Annex A.5.10	<i>Drata Policy Center</i>
Access Control Policy	Annex A.5.15	<i>Drata Policy Center</i>
Operating Procedures for Information Security	Annex A.5.37	<i>Documents (OneDrive)</i>
Incident Management Procedure	Annex A.5.26	<i>Drata Policy Center</i>
Business Continuity Strategy & Procedures	Annex A.5.29	<i>Drata Policy Center</i>
Statutory, Regulatory, And Contractual Requirements	Annex A.5.31	<i>Section 4.2 of the ISMS Plan</i>

CONDITIONAL RECORDS & DOCUMENTS (If Applicable)

Document	Reference	Location
Confidentiality or Non-Disclosure Agreements	Annex A.6.6	<i>Documents (OneDrive)</i>
Secure System Engineering Principles	Annex A.8.27	<i>Confluence Page</i>
Supplier Security Policy	Annex A.5.19	<i>Drata Policy Center</i>

DISCRETIONARY RECORDS & DOCUMENTS (Commonly Used)

Document	Reference	Location
Controls for Managing Records	Clause 7.5.3	<i>Section 7.5.2-.3 of the ISMS Plan</i>
Procedure for Measuring and Monitoring	Clause 9.1	<i>Section 9.1 of the ISMS Plan</i>
Procedure for Corrective Action	Clause 10.2	<i>Confluence Page</i>
Bring Your Own Device (BYOD) Policy	Annex A.8.1	<i>Drata Policy Center</i>
Mobile Device & Teleworking Policy	Annex A.8.1	<i>Drata Policy Center</i>
Information Classification Policy	Annex A.5.12	<i>Drata Policy Center</i>
User Access Rights Policies (Including Password Control)	Annex A.5.18	<i>Drata Policy Center</i>
Disposal & Destruction Policy	Annex A.7.10; A.7.4	<i>Drata Policy Center</i>
Procedures for Working in Secure Areas	Annex A.7.6	<i>Drata Policy Center</i>
Clear Desk & Clear Screen Policy	Annex A.7.7	<i>Drata Policy Center</i>
Change Management Policy	Clause 6.3; Annex A.8.32	<i>Drata Policy Center</i>
Backup Policy	Annex A.8.13	<i>Drata Policy Center</i>
Information Transfer Policy	Annex A.5.14	<i>Drata Policy Center</i>
Business Impact Analysis	Annex A.5.29	<i>Drata Policy Center</i>
ISMS Continuity Controls Testing Plan	Annex A.5.29	<i>Documents (OneDrive)</i>

7.5.2. Creating and updating

Langate Group ensures that documentation generated by Langate Group personnel is appropriately controlled. Consideration is given to:

- Identification of documentation through the assignment of titles, dates, authors, and reference numbers.
- Format including language, version, and media (physical or electronic) used to display and communicate documentation.
- Review and approval for suitability, adequacy, and accuracy of the information contained within the documentation.

The record of this consideration is contained within the “Revision History” table inside of each policy, and records of review and approval are contained within the Drata Policy Center, which documents the policy approval and assigned owner.

7.5.3. Control of documented information

Langate Group’s crucial task in operating and maintaining the ISMS is collecting the appropriate records and evidence to ensure its functionality and effectiveness. The records will also reflect personnel performance and the completion of necessary tasks.

Langate Group will also have a systematic approach to document management. To control documents:

- Classify documents properly
- Define members with the rights for distribution, access, retrieval, and use of documents and the necessary actions to be performed.
- Identify methods currently used to receive, process, approve/reject, store, and/or delete documents.
- Align business processes to document management requirements
- Identify documents for control
- Integrate change controls to ensure the integrity of documents

9. Performance Evaluation / 10. Improvement

9.1. Monitoring, measurement, analysis and evaluation

Langate Group will evaluate its security objectives by monitoring and measuring implemented controls. Monitoring provides awareness of the status and state of assets and processes that have been selected to be watched and can provide basic and immediate alerts if something is not performing as expected. Measurements allow for the evaluation of assets and processes based on predefined units. The assets and processes for evaluation will be properly documented, and the company will produce and maintain reports and evidence of evaluations.

These evaluations are meant to allow the Langate Group to:

- Ensure control objectives are being satisfied and validate the decisions made;
- Establish a roadmap to meet set targets and expectations;
- Produce evidence and justification for implemented measures; and/or,
- Discover and identify security gaps that would require change, corrective action(s), or intervention.

The following systems, processes, and activities could be monitored:

- ISMS Implementation
- Incident Management
- Vulnerability Management
- Configuration Management
- Security Awareness and Training
- Access Control, Firewall, and other Event Logging
- Audits
- Risk Assessment Process
- Risk Treatment Process
- Third-Party Risk Management
- Business Continuity Management
- Physical and Environmental Security Management
- System Monitoring

The following processes and activities could be measured:

- Planning
- Leadership
- Risk Management
- Policy Management
- Resource Management
- Communicating
- Management Review
- Documenting
- Auditing

Effectiveness measures will be used to evaluate the effectiveness and impact of the risk treatment plan and related processes and controls related to the information security objectives. These measures could include:

- Cost savings resulting from properly operating the ISMS, or costs incurred from addressing incidents
- Level of customer trust
- Achievement of other information security objectives

9.2. Internal audit

Internal Audits are a crucial element of Langate Group's ISMS and its continuous improvement. The process will ensure the discovery and identification of issues, gaps, malfunctions, etc., in the company's ISMS that could ultimately damage or harm the company.

- **Frequency.** Langate Group will conduct an internal audit of its ISMS (at least annually).
- **Audit Entity.** Langate Group internal audits will be conducted by:
 - Employee or contractor, full-time auditor;
 - Employee or contractor, part-time auditor;
 - Third-party internal auditor (outside organization will conduct internal audit per rules set by Langate Group)
- **Documentation.** Langate Group will set and document the criteria and scope of each 1 time per year internal audit in the Internal Audit Program. It will also produce and maintain, for evidence, reports of the internal audit, where findings, gaps, and nonconformities will be outlined.
- Langate Group will include in its **Internal Audit Program** sections such as:
 - Method of Internal Auditor Selection
 - Process of planning the internal audit
 - Steps to conduct the internal audit
 - Post-audit activities
 - Internal audit checklist
- **Plan and Procedure (See APPENDIX A).**

9.3. Management review / 10.1. Continual improvement / 10.2. Nonconformity and corrective action

- **Management review.** Langate Group management will systematically review and make critical decisions concerning the ISMS. The review will be arranged by the ISMS Manager, who is also responsible for compiling all necessary information and inputs for consideration.
The review will take into consideration:
 - Status of items, issues, and tasks from the previous review
 - Any internal and external changes that impact security
 - Feedback from, and any security-related changes in needs and expectations of, interested parties
 - Feedback on the performance of the ISMS, to include:
 - Nonconformities and corrective actions
 - Monitoring and measurement results
 - Audit results
 - Fulfillment of information security objectives
 - Risk assessment results and risk treatment status
 - Continual improvement opportunities
 - The ISMS scope and whether it requires modifications
 - Security policies and whether any require modifications
 - Security gaps and necessary improvements
 - Necessary resources
 - The overall effectiveness of the ISMS and fulfillment of its objectives
 - Implementation of different security strategies and training
- **Frequency.** Langate Group will conduct a management review of its ISMS 1 time per year and as necessary.
- **Documentation and reporting.** The considerations, discussions, and decisions from the management review will be recorded in the meeting minutes, which could also include discussions from other reviews. The results

of the review and subsequent tasks and responsibilities will be communicated to relevant parties by [METHOD, e.g., e-mail, meeting, all-hands, etc.].

- **Corrective Action Plan.** In the event of a nonconformity, Langate Group will take action to control and correct it or deal with the consequences, as applicable. Langate Group will employ corrective action plans for the systematic elimination of issues and non-conformities. The plan will aim to resolve an issue from its root cause so that it can be prevented or mitigated in the future and sustain the corrective measures. It will include:
 - Review of the nonconformity
 - Root cause analysis and assessment
 - Determination of whether similar nonconformities are present or could occur
 - Required steps for root cause elimination
 - Implementing changes to the ISMS, if necessary
 - Risk-opportunity assessment of changes and review of their effectiveness
 - Time and cost assessment
 - Rubric for measuring effectiveness
- **Corrective Action Report.** Langate Group will document any corrective action taken in a corrective action report. The report should include:
 - Nature of non-conformities
 - Identified root cause
 - Corrective actions taken
 - Implementation of corrective actions
 - Result of corrective actions (include effectiveness)

APPENDIX A

Internal Audit Plan and Procedure

Purpose

The purpose of the internal audit is to ensure the effectiveness of Langate Group's information security management system, its continuous improvement, and conformance with the requirements of ISO 27001:2022, as set out in Clause 9.2 of the standard. It will ensure (a) conformance with the standard and, more importantly, (b) proper information security measures in place that are continuously improved. Additionally, the internal audit will:

- Uncover nonconformities before others discover them;
- Ensure a strong security stance by identifying areas that require attention prior to a security event;
- Demonstrate and inform management commitment; and
- Assist staff with understanding and awareness.

Scope

This plan applies to Langate Group internal audits of the ISMS, and establishes the procedures for carrying out the audit. The audit scope should match the ISMS.

Roles and responsibilities

Lead Auditor: Responsible for the planning and execution of the audit. The lead auditor is a competent entity independent from the ISMS, who is [a member of the company independent of the ISMS, OR a third party auditor].

Responsible for assisting in the audit process, when and as required.

Plan

- Audit schedule.
 - Properly planned out audit and readily available schedule to let all members know when each process will be audited over the upcoming cycle.
 - Allow time for better preparation and practical support.
 - Allow time for process owners to.
 1. finish any improvement projects and gather valuable information on the implementation; or,
 2. request that the auditor(s) focus on helping to gather information for other planned improvements.
- Coordinate with process owners.
 - Collaborate to determine the best time to review the process.
 - Auditor(s) can review previous audits to see if any follow-up is required on comments or concerns previously found.
 - Process owners can identify any areas that the auditor can look at to assist the process owner to identify information.
 - Ensure that the process owners will get value out of the audit process.
- Conducting the audit.
 - Gather, review, and analyze information as outlined in the audit procedures below.
 - Identify areas that do not have operational evidence.
 - Identify areas that may function better if changes are made.
- Reporting audit findings.
 - Meet with interested parties and process owners to ensure an efficient flow of information (non-conforming).
 - Highlight areas of weakness to be addressed and areas that could use improvement (improvement opportunities).
- Follow-up.
 - Ensure that identified areas of non-conformity are resolved and corrective actions have been taken.
 - Check any progress on identified improvement opportunities.

Procedure

- Review ISMS documentation.
 - The audit scope should match ISMS, setting clear limits for the internal audit.
 - All prescribed documents are in place and readily available.
- Identify any criteria, if any, needed for consideration during the audit
 - Identify the extent of work that may be done during the audit.
 - Identify any anticipated limitations.
- Identify the main stakeholders in the ISMS
- Management input
 - Designated internal auditor should be competent and independent.
 - Agree and determine the timing and resources required for the audit.
 - Set milestones/checkpoints for when the board should receive interim updates.
 - Discuss issues or concerns
- Conduct a practical assessment
 - Observe the operation of the ISMS and whether it properly functions in practice by speaking with members involved and operating processes related to the ISMS, whether they are in an ISMS role or

- not.
- Run audit tests to validate evidence as it is gathered.
- Complete audit reports and document the results of each test.
- Analyze evidence
 - Sort and review all evidence collected during the audit, as related to the company's risk treatment plan and control objectives.
 - Identify any further gaps or need for further audit tests.
- Report findings. The report should include:
 - Classification and dissemination restrictions of the report
 - The intended recipient(s) of the report
 - An executive summary to highlight the key findings, high-level analysis, and a conclusion
 - Scope, Timing, any outlined criteria
 - Analysis of the findings and compliance with each clause of the ISMS requirements
 - Recommendations
 - Post-audit actions

Policy version history

 Policy details

Policy name	Renewal date
Information Security Management System (ISMS) Plan 2022	May 6, 2027
Description	
The ISMS Plan aims to define the principles, requirements, and basic rules for the establishment, implementation and operation of an Information Security Management System.	

 Version history

Version 1					
Creation date	Approval date	Published date	Owner	Approver(s)	Publisher
November 28, 2023	January 24, 2024	January 24, 2024	Eugene Skubach	Eugene Skubach	Eugene Skubach
Version 1.1					
Creation date	Approval date	Published date	Owner	Approver(s)	Publisher
January 11, 2025	No approval required	February 11, 2025	Eugene Skubach	-	Eugene Skubach
Version 1.2					
Creation date	Approval date	Published date	Owner	Approver(s)	Publisher
February 11, 2025	No approval required	May 2, 2025	Eugene Skubach	-	Eugene Skubach
Version 1.3					
Creation date	Approval date	Published date	Owner	Approver(s)	Publisher
May 6, 2025	No approval required	May 6, 2025	Eugene Skubach	-	Eugene Skubach

Version 1.4

Creation date	Approval date	Published date	Owner	Approver(s)	Publisher
May 20, 2025	No approval required	May 20, 2025	Eugene Skubach	-	Eugene Skubach

Version 1.5

Creation date	Approval date	Published date	Owner	Approver(s)	Publisher
June 11, 2025	No approval required	June 15, 2025	Eugene Skubach	-	Eugene Skubach

Version 1.6

Creation date	Approval date	Published date	Owner	Approver(s)	Publisher
June 22, 2025	No approval required	June 22, 2025	Eugene Skubach	-	Eugene Skubach

Version 1.7

Creation date	Approval date	Published date	Owner	Approver(s)	Publisher
June 29, 2025	No approval required	June 30, 2025	Eugene Skubach	-	Eugene Skubach

Version 1.8

Creation date	Approval date	Published date	Owner	Approver(s)	Publisher
July 2, 2025	No approval required	July 2, 2025	Eugene Skubach	-	Eugene Skubach

Version 2

Creation date	Approval date	Published date	Owner	Approver(s)	Publisher
July 7, 2025	July 7, 2025	July 7, 2025	Eugene Skubach	Eugene Skubach	Eugene Skubach

Version 2.1

Explanation of changes

'Revision History' section has been removed

Creation date	Approval date	Published date	Owner	Approver(s)	Publisher
September 26, 2025	No approval required	September 26, 2025	Eugene Skubach	-	Eugene Skubach

Version 3

Explanation of changes

Updated objectives (Year 1 Post-Certification)

Creation date	Approval date	Published date	Owner	Approver(s)	Publisher
May 6, 2026	No approval required	-	Eugene Skubach	Eugene Skubach	-
